

SonarQube (Static Analysis Code Tool)

In real-time projects, developers write thousands or even lakhs of lines of code. Performing **manual code reviews** for each line is not only time-consuming but also prone to human error.

To address this, we use **SonarQube**, a powerful **static code analysis tool**. It automatically scans the source code and helps identify issues such as:

- Non-compliance with coding standards
- Code smells
- Bugs and vulnerabilities
- Duplicated or inefficient code

By doing so, SonarQube ensures that developers maintain consistent **coding standards** and improve the overall **quality and reliability** of the application.

Code Review

Traditionally, senior developers or technical leads were responsible for reviewing code.

- **Agile Methodology:** Code review often follows a peer-to-peer approach, where teammates review each other's work.
- **Client Side:** In many projects, senior architects on the client side also review the code for compliance with standards and best practices.

However, regardless of the process, the first and most important step is performing static code analysis to automatically detect issues.

Popular Static Analysis Tools

- **Veracode** (commercial license required)
- **HP Fortify** (commercial license required)
- **SonarQube** (widely used, with editions such as:
 - **Community Edition** → free, supports 16 programming languages
 - **Developer / Enterprise Editions** → paid, with advanced features and extended language support)

Code Review vs Code Coverage

- **Code Review:** Validates whether developers follow coding standards and best practices.
- **Code Coverage:** Measures how much of the code is executed by unit test cases. To improve coverage, developers need to write more comprehensive test cases.

Unlike **Maven** and **Tomcat**, which are developed in Java and primarily support **Java applications only**, tools like **SonarQube**, **Nexus**, and **Jenkins** are also developed in Java but are designed to support **multiple programming languages** and diverse technology stacks.

SonarQube - Introduction

- 1) SonarQube (previously called **Sonar**) is an open-source software quality management tool.
- 2) It will continuously analyse and measures quality of the source code.
- 3) I will generate the report if any issues in html format/PDF format.
- 4) It is a web-based tool supports multiple languages (Java, C#, JS ...)
- 5) It will support multi-OS platform (Windows. MAC, Linux...).
- 6) It will support multiple databases (MySQL, Oracle, Microsoft SQL Server, PostgreSQL.)
- 7) Supports multiple browsers (IE, Microsoft Edge, FF, Chrome, Safari)
- 8) It will identify the below category of issues.
 - **Duplicated code**
 - **Coding standards**
 - **Unit tests**
 - **Complex code**
 - **Comments**
 - **Potential Bugs**
 - **Architecture & Design**

Some popular Relational Databases:

Oracle

MySQL

Postgres SQL

MS SQL server



Relational Databases are structured format where data is stored in the format of Rows and Columns (tables) like spreadsheet

DB2

Sybase

Non-Relational Databases:

MongoDB

Cloudant

Couch DB

Dynamo DB

Data is stored in the format of JSON format like document

Document (non-relational) == Table (Relational)

In real-time applications, data is typically stored in a database. Similarly, **SonarQube** uses a database to store the reports it generates during static code analysis.

Supported Databases (Latest Versions)

- **Oracle**
- **PostgreSQL**
- **MS SQL Server**
- **MySQL**

◆ PostgreSQL and MySQL are **open-source databases**.

◆ Oracle and MS SQL Server are **commercial relational databases** that require licensing.

SonarQube Without an External Database

By default, SonarQube provides an in-built **H2 database**.

- If no external database is configured, SonarQube uses this embedded database to store reports.
- However, in **real-time/production environments**, it is strongly recommended to use a dedicated external database (e.g., PostgreSQL, Oracle, MS SQL) for scalability and reliability.

Examples of Issues Detected by SonarQube

1. Complex Code (Nested Conditions):

Example: Overuse of nested if-else statements inside a function, making the code difficult to read and maintain.

```
doAddition() {  
    // Nested if-else logic (bad practice)  
}
```

SonarQube flags such cases and suggests simplifying the logic.

2. Commented-Out Code:

- Sometimes developers leave large sections of code commented for “future use.”
- SonarQube highlights these as **unnecessary clutter** and recommends removing them.

Exception Handling Mechanism in Java

SonarQube also checks proper usage of exception handling:

- **try** → Code block that may throw an exception.
- **catch** → Handles the exception when it occurs.
- **finally** → Executes regardless of whether an exception occurred (used for cleanup tasks).
- **throw** → Used to explicitly throw an exception.
- **throws** → Declares the exceptions a method might throw.

SonarQube – Language Support

- Initially, SonarQube was developed exclusively for **Java** projects.
- Today, it supports **20+** programming languages, making it a versatile tool for diverse technology stacks.

Commercially Supported Languages

- ABAP

- C Family (C, C++, Objective-C)
- COBOL
- PL/SQL
- Visual Basic
- Natural
- VB.Net
- RPG
- Swift

Open-Source Supported Languages

- Java
- JavaScript
- C#
- Web (HTML, JSP, JSF, etc.)
- XML
- Python
- Groovy
- PHP
- Puppet
- Lua
- FxCop
- Flex
- Erlang

SonarQube – Pre-requisites

To run SonarQube v6.2 and later, the following prerequisites are required:

- **Java**
 - Oracle JRE 8+ or OpenJDK 8+ (mandatory)
- **Databases (Optional, for persistent storage)**

- MySQL 5.6+
- Oracle 11g+

If no external database is configured, **SonarQube** will use its embedded **H2** database by default.

However, this is only recommended for testing or evaluation purposes — not for production environments, as it does not support multi-user or large-scale setups.

SonarQube Platform Architecture:

The SonarQube platform is composed of four main components:

1. SonarQube Server – runs three core processes:

- **Web Server** – provides the user interface and dashboards
- **Search Server** – handles indexing and searching of code analysis data
- **Compute Engine** – processes analysis reports and stores results in the database

2. SonarQube Database

- Stores all project data, quality profiles, analysis reports, and configuration settings

3. SonarQube Plugins

- Extend SonarQube capabilities (e.g., support for more languages, quality gates, rules)

4. SonarQube Scanners

- Client-side tools used to analyze the source code and send reports to the SonarQube server

How SonarQube Works

- **SonarQube Scanner** is the component that analyses the source code (e.g. Java, C/C#, Python) line by line.
- After scanning, it generates a report and sends it to the **SonarQube Server**.
- The report is then stored in a database — either an **external database** (like PostgreSQL, Oracle, Microsoft SQL Server) or the **embedded H2 database**.
- Within the **SonarQube Server**:

- The **Compute Engine** processes the report and classifies issues into three categories:
 - **Vulnerabilities**
 - **Bugs**
 - **Code Smells**
- The **Web Server** displays these reports on the SonarQube dashboard (UI).
- The **Search Engine** inside the Web Server enables fast searching and retrieval of reports.

Installing SonarQube

Pre-requisites

- Java 11 (mandatory)
- SonarQube 9.x version (recommended)

Hardware Requirements

- Minimum 4 GB RAM
- t2.medium instance – chargeable (recommended for stable usage)

Installation Steps

1. Login as root user
2. `sudo su -`
3. Install Java (Pre-requisite)

`yum install java-11-openjdk-devel -y`

```
root@ip-172-31-41-178:~$ sudo su -
[ec2-user@ip-172-31-41-178 ~]$ sudo su -
Last login: Tue Sep  2 16:55:14 UTC 2025 on pts/1
[root@ip-172-31-41-178 ~]# sudo yum install java-11-amazon-corretto-devel
Amazon Linux 2023 Kernel Livepatch repository                               166 kB/s | 19 kB    00:00
Dependencies resolved.
=====
Package                                Architecture Version                                Repository          Size
=====
Installing:
java-11-amazon-corretto-devel          x86_64      1:11.0.28+6-1.amzn2023                amazonlinux          211 k
Installing dependencies:
alsa-lib                                x86_64      1.2.7.2-1.amzn2023.0.2                amazonlinux          504 k
cairo                                   x86_64      1.18.0-4.amzn2023.0.2                 amazonlinux          717 k
dejavu-sans-fonts                       noarch      2.37-16.amzn2023.0.2                  amazonlinux          1.3 M
dejavu-sans-mono-fonts                  noarch      2.37-16.amzn2023.0.2                  amazonlinux          467 k
dejavu-serif-fonts                      noarch      2.37-16.amzn2023.0.2                  amazonlinux          1.0 M
fontconfig                              x86_64      2.13.94-2.amzn2023.0.2                amazonlinux          273 k
fonts-filestystem                       noarch      1:2.0.5-12.amzn2023.0.2               amazonlinux          9.5 k
freetype                                x86_64      2.13.2-5.amzn2023.0.1                 amazonlinux          423 k
google-noto-fonts-common                noarch      20240401-1.amzn2023.0.2               amazonlinux          17 k
google-noto-sans-vf-fonts               noarch      20240401-1.amzn2023.0.2               amazonlinux          593 k
graphite2                                x86_64      1.3.14-7.amzn2023.0.2                 amazonlinux          97 k
harfbuzz                                 x86_64      7.0.0-2.amzn2023.0.2                  amazonlinux          873 k
java-11-amazon-corretto-headless        x86_64      1:11.0.28+6-1.amzn2023                amazonlinux          91 M
javapackages-filestystem                noarch      6.0.0-7.amzn2023.0.6                  amazonlinux          12 k
langpacks-core-font-en                  noarch      3.0-21.amzn2023.0.4                   amazonlinux          10 k
libx11                                   x86_64      1.8.10-2.amzn2023.0.1                 amazonlinux          659 k
libx11-common                           noarch      1.8.10-2.amzn2023.0.1                 amazonlinux          147 k
libxau                                    x86_64      1.0.11-6.amzn2023.0.1                 amazonlinux          33 k
libxext                                  x86_64      1.3.6-1.amzn2023.0.1                  amazonlinux          42 k
libxrender                               x86_64      0.9.11-6.amzn2023.0.1                 amazonlinux          29 k
libbrotli                                x86_64      1.0.9-4.amzn2023.0.2                  amazonlinux          315 k
libjpeg-turbo                           x86_64      2.1.4-2.amzn2023.0.5                  amazonlinux          190 k
libpng                                    x86_64      2:1.6.37-10.amzn2023.0.6              amazonlinux          128 k
```

Download SonarQube Server Software

1. Navigate to the /opt directory
2. cd /opt
3. Install required utilities (wget and unzip)
4. yum install wget unzip -y
5. Download the SonarQube 9.6.1 distribution zip

wget <https://binaries.sonarsource.com/Distribution/sonarqube/sonarqube-9.6.1.59531.zip>

```

[root@ip-172-31-41-178 ~]# java -version
openjdk version "11.0.28" 2025-07-15 LTS
OpenJDK Runtime Environment Corretto-11.0.28.6.1 (build 11.0.28+6-LTS)
OpenJDK 64-Bit Server VM Corretto-11.0.28.6.1 (build 11.0.28+6-LTS, mixed mode)
[root@ip-172-31-41-178 ~]# cd /opt/
[root@ip-172-31-41-178 opt]# ls
aws
[root@ip-172-31-41-178 opt]# yum install wget unzip -y
Last metadata expiration check: 0:01:17 ago on Tue Sep 2 16:56:21 2025.
Package wget-1.21.3-1.amzn2023.0.4.x86_64 is already installed.
Package unzip-6.0-57.amzn2023.0.2.x86_64 is already installed.
Dependencies resolved.
Nothing to do.
Complete!
[root@ip-172-31-41-178 opt]# wget https://binaries.sonarsource.com/Distribution/sonarqube/sonarqube-9.6.1.59531.zip
--2025-09-02 17:00:30-- https://binaries.sonarsource.com/Distribution/sonarqube/sonarqube-9.6.1.59531.zip
Resolving binaries.sonarsource.com (binaries.sonarsource.com)... 108.159.61.18, 108.159.61.59, 108.159.61.118, ...
Connecting to binaries.sonarsource.com (binaries.sonarsource.com)|108.159.61.18|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 290033351 (277M) [binary/octet-stream]
Saving to: 'sonarqube-9.6.1.59531.zip'

sonarqube-9.6.1.59531.zip 100%[=====>] 276.60M 121MB/s in 2.3s
2025-09-02 17:00:33 (121 MB/s) - 'sonarqube-9.6.1.59531.zip' saved [290033351/290033351]

[root@ip-172-31-41-178 opt]# ls
aws sonarqube-9.6.1.59531.zip
[root@ip-172-31-41-178 opt]#

```

6. Unzip the downloaded SonarQube package

unzip sonarqube-9.6.1.59531.zip

 This will extract the **SonarQube** files into a directory named sonarqube-9.6.1.59531 inside /opt.

```

[root@ip-172-31-41-178 opt]# ls
aws sonarqube-9.6.1.59531.zip
[root@ip-172-31-41-178 opt]# unzip sonarqube-9.6.1.59531.zip
Archive: sonarqube-9.6.1.59531.zip
  creating: sonarqube-9.6.1.59531/
  inflating: sonarqube-9.6.1.59531/dependency-license.json
  creating: sonarqube-9.6.1.59531/bin/
  creating: sonarqube-9.6.1.59531/bin/windows-x86-64/
  inflating: sonarqube-9.6.1.59531/bin/windows-x86-64/SonarService.bat
  creating: sonarqube-9.6.1.59531/bin/windows-x86-64/lib/
  inflating: sonarqube-9.6.1.59531/bin/windows-x86-64/lib/SonarServiceWrapper.exe
  inflating: sonarqube-9.6.1.59531/bin/windows-x86-64/lib/find_java.bat
  creating: sonarqube-9.6.1.59531/bin/winsw-license/
  inflating: sonarqube-9.6.1.59531/bin/winsw-license/LICENSE.txt
  creating: sonarqube-9.6.1.59531/temp/
  inflating: sonarqube-9.6.1.59531/temp/README.txt
  inflating: sonarqube-9.6.1.59531/COPYING
  creating: sonarqube-9.6.1.59531/logs/
  inflating: sonarqube-9.6.1.59531/logs/README.txt
  creating: sonarqube-9.6.1.59531/extensions/
  creating: sonarqube-9.6.1.59531/extensions/jdbc-driver/
  creating: sonarqube-9.6.1.59531/extensions/jdbc-driver/oracle/
  inflating: sonarqube-9.6.1.59531/extensions/jdbc-driver/oracle/README.txt
  creating: sonarqube-9.6.1.59531/extensions/plugins/
  inflating: sonarqube-9.6.1.59531/extensions/plugins/README.txt
  creating: sonarqube-9.6.1.59531/data/
  inflating: sonarqube-9.6.1.59531/data/README.txt
  creating: sonarqube-9.6.1.59531/elasticsearch/
  creating: sonarqube-9.6.1.59531/elasticsearch/lib/
  inflating: sonarqube-9.6.1.59531/elasticsearch/lib/elasticsearch-7.17.4.jar
  inflating: sonarqube-9.6.1.59531/elasticsearch/lib/java-version-checker-7.17.4.jar
  inflating: sonarqube-9.6.1.59531/elasticsearch/lib/elasticsearch-launchers-7.17.4.jar
  inflating: sonarqube-9.6.1.59531/elasticsearch/lib/elasticsearch-x-content-7.17.4.jar
  inflating: sonarqube-9.6.1.59531/elasticsearch/lib/elasticsearch-lz4-7.17.4.jar

```

7. Rename the extracted directory for simplicity

mv sonarqube-9.6.1.59531 sonarqube

📁 This renames the folder to just **sonarqube**, making it easier to navigate and manage.

```
[root@ip-172-31-41-178 opt]# mv sonarqube-9.6.1.59531 sonarqube
[root@ip-172-31-41-178 opt]# ls
aws sonarqube sonarqube-9.6.1.59531.zip
```

⚙️ Configuration and User Setup for SonarQube

- By default, SonarQube runs on port **9000**.
- To change the default port or configure an external database, edit the file:
- **/opt/sonarqube/conf/sonar.properties**
- Inside the **bin/** directory, you'll find platform-specific folders (Linux, macOS, Windows).
Use the appropriate folder based on your operating system to start SonarQube.

👤 Create a Dedicated Sonar User

- **Running SonarQube as root is not allowed** (due to security restrictions and its dependency on Elasticsearch, which also cannot run as root).
- As a best practice, create a separate **sonar user** to run the SonarQube service:
- **useradd sonar**

(Optionally, grant **sudo** access if needed for managing the service.)

```
[root@ip-172-31-41-178 opt]# cd sonarqube/
[root@ip-172-31-41-178 sonarqube]# ls
COPYING bin conf data dependency-license.json elasticsearch extensions lib logs temp web
[root@ip-172-31-41-178 sonarqube]# cd bin/
[root@ip-172-31-41-178 bin]# ls
linux-x86-64 macosx-universal-64 windows-x86-64 winsw-license
[root@ip-172-31-41-178 bin]# useradd sonar
[root@ip-172-31-41-178 bin]# |
```

🔒 Grant sudo Access to the sonar User

Open the sudoers file using the visudo command:

visudo

```
[root@ip-172-31-41-178 opt]# visudo|
```

In the file (which opens in **nano editor**), scroll to the bottom and add this line:

1. **sonar ALL=(ALL) NOPASSWD:ALL**

2. Save and exit the file:

- **Ctrl + O** → Write out (save)
- **Enter** → Confirm filename
- **Ctrl + X** → Exit the editor

✓ The sonar user now has password less sudo privileges to manage the **SonarQube** service.

```
GNU nano 8.3 /etc/sudoers.tmp
# Defaults    env_keep += "HOME"
Defaults    secure_path = /usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/var/lib/snapd/snap/bin

## Next comes the main part: which users can run what software on
## which machines (the sudoers file can be shared between multiple
## systems).
## Syntax:
##
##     user    MACHINE=COMMANDS
##
## The COMMANDS section may have other options added to it.
##
## Allow root to run any commands anywhere
root    ALL=(ALL)    ALL
sonar    ALL=(ALL)    NOPASSWD: ALL
## Allows members of the 'sys' group to run networking, software,
## service management apps and more.
# %sys ALL = NETWORKING, SOFTWARE, SERVICES, STORAGE, DELEGATING, PROCESSES, LOCATE, DRIVERS

## Allows people in group wheel to run all commands
%wheel  ALL=(ALL)    ALL

## Same thing without a password
# %wheel    ALL=(ALL)    NOPASSWD: ALL

## Allows members of the users group to mount and unmount the
## cdrom as root
# %users    ALL=/sbin/mount /mnt/cdrom, /sbin/umount /mnt/cdrom

AG Help      AO Write Out  AF Where Is  AK Cut       AT Execute  AC Location  M-U Undo
AX Exit      AR Read File  AL Replace   AU Paste     AJ Justify  AV Go To Line M-E Redo
```

📁 Set Ownership and Permissions for SonarQube Directory

Assign the sonar user as the owner and grant proper permissions to the `/opt/sonarqube/` directory:

chown -R sonar:sonar /opt/sonarqube/

chmod -R 775 /opt/sonarqube/

- **chown -R sonar:sonar** → Recursively changes the owner and group to sonar
- **chmod -R 775** → Gives read, write, and execute permissions to owner & group, and read & execute to others

```
[root@ip-172-31-41-178 opt]# ls -l
total 283236
drwxr-xr-x.  4 root  root      33 Aug 13 21:08 aws
drwxrwxr-x. 11 sonar sonar    172 Aug 29 2022 sonarqube
-rw-r--r--.  1 root  root 290033351 Aug 29 2022 sonarqube-9.6.1.59531.zip
[root@ip-172-31-41-178 opt]# |
```

▶ Start SonarQube as sonar User

Switch to the sonar user

```
su - sonar
```

Navigate to the Linux binaries directory

```
cd /opt/sonarqube/bin/linux-x86-64/
```

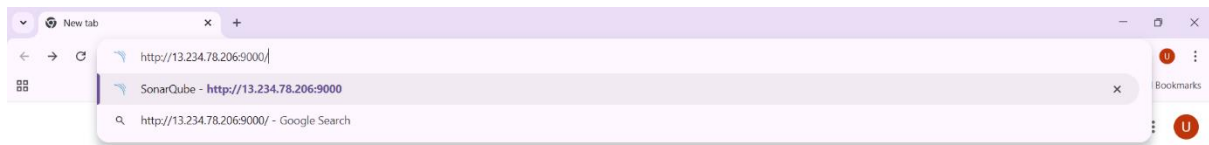
Inside this directory, you will find the **sonar.sh** script — this is the script used to **start** the **SonarQube** server.

```
[root@ip-172-31-41-178 opt]# su -sonar
su: failed to execute onar: No such file or directory
[root@ip-172-31-41-178 opt]# su - sonar
[sonar@ip-172-31-41-178 ~]$ cd /opt/sonarqube/bin/linux-x86-64/
[sonar@ip-172-31-41-178 linux-x86-64]$ pwd
/opt/sonarqube/bin/linux-x86-64
[sonar@ip-172-31-41-178 linux-x86-64]$ ls
sonar.sh
```

- Then we are going to pass the argument and start the sonarqube server as below
- **sh sonar.sh start**

```
[sonar@ip-172-31-41-178 linux-x86-64]$ sh sonar.sh start
/usr/bin/java
Starting SonarQube...
Started SonarQube.
[sonar@ip-172-31-41-178 linux-x86-64]$ sh sonar.sh status
/usr/bin/java
SonarQube is running (27304).
[sonar@ip-172-31-41-178 linux-x86-64]$ |
```

- Once the SonarQube server is started, we need to enable the required port (**default: 9000**) in the AWS Security Group of the instance.
- In real-time environments, we only open the specific ports required for the application to enhance security, instead of allowing all ports.
- After enabling the port, SonarQube can be accessed using:
- **http://<public-ip>:9000**



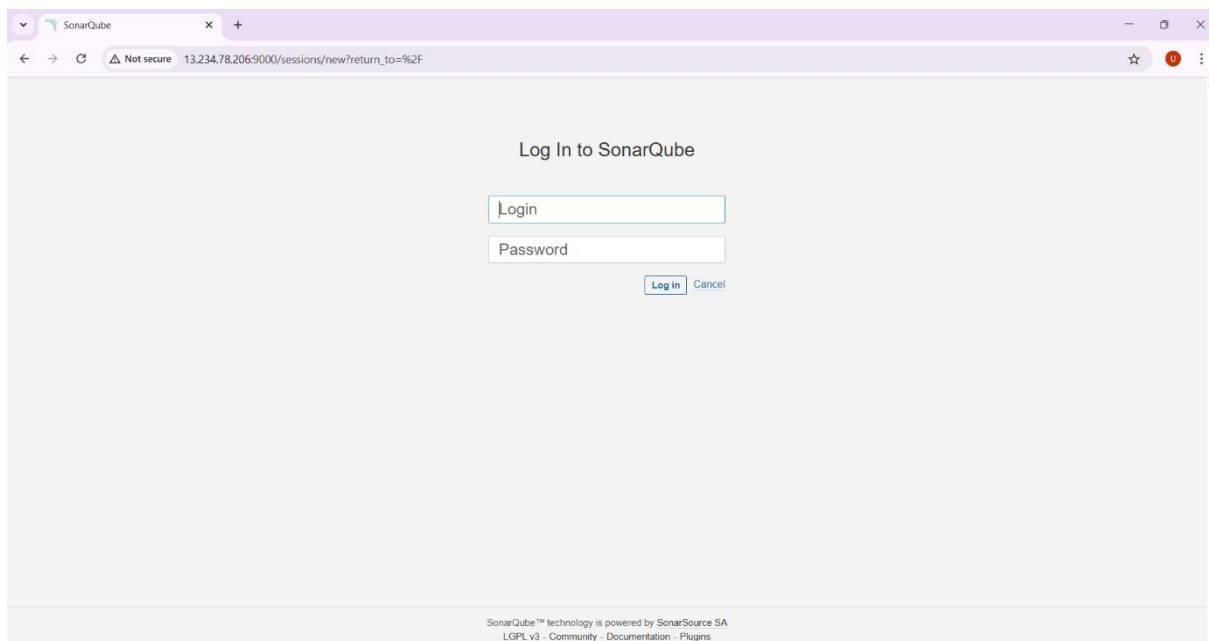
Google

Search Google or type a URL



Customise Chrome

- When you access SonarQube in the browser (`http://<public-ip>:9000`), it will prompt for login credentials.
- Use the default credentials to sign in for the first time:
- **Username:** admin
- **Password:** admin
- It is strongly recommended to change the default password immediately after the first login for security reasons.



- Post this it will ask to update the default password to new password.

The screenshot shows a web browser window with the address bar displaying '13.234.78.206:9000/account/reset_password'. The main content area features a white box titled 'Update your password'. Inside the box, it states 'This account should not use the default password.' and 'Enter a new password'. Below this, a note says 'All fields marked with * are required'. There are three input fields: 'Old Password *', 'New Password *', and 'Confirm Password *'. Each field contains a series of dots representing masked characters. An 'Update' button is located at the bottom of the form.

The screenshot shows the SonarQube web interface. At the top, there is a navigation bar with links for 'Projects', 'Issues', 'Rules', 'Quality Profiles', 'Quality Gates', and 'Administration'. A search bar is also present. Below the navigation bar, a red banner displays a warning: 'You're running a version of SonarQube that is past end of life. Please upgrade to a supported version immediately.' with a 'Learn More' link. The main section is titled 'How do you want to create your project?'. It provides instructions on benefiting from SonarQube's features and mentions the need for a DevOps platform configuration. Four options are shown in boxes: 'From Azure DevOps', 'From Bitbucket', 'From GitHub', and 'From GitLab', each with a 'Set up global configuration' link. At the bottom, there is a 'Manually' option with a code icon and a link to 'Create a project manually'.

- Now we can able to access the SonarQube through web browser post changing the default username and password.

⚠ Common Issue: SonarQube Status Shows “Not Running”

- If we start SonarQube using the **root user**, it may display “*SonarQube is running*”, but when we check the status, it will actually show “*SonarQube is not running*”.
- This happens because:
 - When started as root, SonarQube creates a **conf/** directory inside the **/tmp/** directory with root ownership.

- Later, if we try to start SonarQube using the sonar user, it **cannot access that root-owned conf/ directory**, causing startup failure.
-  **Best Practice:** Always **start SonarQube using the sonar user**, not as root.
-  **Fix:** If you accidentally started it as root earlier:
 1. Stop the server.
 2. Remove the **root-owned conf/ directory inside /tmp/**.
 3. Start the SonarQube server again using the sonar user.

Generating SonarQube Reports for Projects

- To generate a SonarQube report for a Apache Maven-based Java project, we configure the **SonarQube** server URL in the **<properties>** section of the project's pom.xml file.
- Then, run the command:
- **mvn sonar:sonar**
 - The first sonar refers to the **plugin name**
 - The second sonar refers to the **goal name**
 - This uses the SonarQube Scanner plugin to analyze the code and send results to the SonarQube server.
- After the scan completes, we can share the SonarQube URL, username, and password with developers to access the report.

 **Bugs and Vulnerabilities** reported by SonarQube must be fixed immediately, as leaving them unresolved could impact the application.

Using Tokens Instead of Passwords

- Instead of storing the SonarQube username and password inside pom.xml, it is more secure to use an **authentication token**.
- Generate a token as follows:
 - In SonarQube navigate to: **Administrator** → **Security** → **Generate Token**
 - Set **Expiration** to **No Expiration** (commonly used in real-time environments).

- Add the token in pom.xml:
 - **<sonar.login>your_generated_token</sonar.login>**
 - This token can be reused across **multiple projects** that point to the same SonarQube server.
-

Running SonarQube Analysis on Node.js Projects

- For JavaScript or Node.js projects, we use **package.json** instead of pom.xml.
- Install Node.js (if not installed):
- `sudo yum install nodejs -y`
- Install project dependencies:
- `npm install`

This creates a node_modules directory containing all required packages.

THANK YOU
